



Digital Forensics Incident Response (DFIR) Workflow & Malware Analysis

Presentation By :

Trillium InfoSec Systems



What is DFIR?

DIGITAL FORENSICS (DF)

- The scientific process of collecting, preserving, analyzing, and presenting digital evidence in a way that is legally sound and court-admissible.

THE CORE TENSION

- Forensics demands patience. Image everything, document every step, preserve chain of custody.
- Incident Response demands speed. Contain the threat before more damage is done.
- DFIR practitioners must balance both the IR Lead and Forensic Examiner coordinate from the first alert.

INCIDENT RESPONSE (IR)

- The structured approach to handling and managing the aftermath of a security breach or cyberattack - to limit damage, reduce recovery time and cost.

DFIR TOGETHER - WHEN IT'S TRIGGERED

- Ransomware or destructive malware detected
- Suspected data exfiltration or insider threat
- Regulatory notification obligation triggered
- Unusual account behaviour or persistent intrusion



Why DFIR Matters



Identify the Breach

- What was accessed, exfiltrated or destroyed?
- Which systems and accounts were compromised?
- What is the true scope of impact?

Stop the Attacker

- Contain active threats before further damage
- Prevent reinfection after remediation
- Cut off C2 channels and persistence mechanisms

Preserve Evidence

- Collect forensic-grade data for legal use
- Maintain chain of custody throughout
- Support law enforcement or civil proceedings

Meet Legal Obligations

- Mandatory breach notification (GDPR, PDP etc.)
- Regulatory reporting within defined windows
- Demonstrate due diligence to auditors

Restore Operations

- Recover systems from clean verified backups
- Minimise downtime and business disruption
- Validate restoration before reconnecting

Improve Defences

- Root-cause analysis drives control improvements
- Update detection rules and playbooks
- Every incident makes the next one easier to handle

DFIR Roles & Team Structure



IR Lead / Incident Commander

- Owns the incident end-to-end - declares, manages, closes
- Coordinates IT, Legal, Comms, Executive leadership
- Makes containment and escalation decisions in real time
- Produces executive-facing incident status updates

Forensic Examiner

- Acquires and preserves evidence - disk, memory, logs
- Maintains chain of custody and forensic documentation
- Performs timeline analysis and artefact correlation
- Produces forensic reports suitable for legal proceedings

Malware Analyst

- Performs static, dynamic and reverse-engineering analysis
- Identifies malware family, capabilities, C2 infrastructure
- Extracts IOCs for detection rule creation
- Assesses business impact of malware behaviour

Threat Hunter

- Proactively searches for hidden attacker presence
- Hypothesis-driven hunting across SIEM/EDR telemetry
- Identifies lateral movement, persistence, dwell time
- Operates during and between incidents

SOC / Triage Analyst

- First responder - triages alerts, escalates to IR Lead
- Collects initial artefacts, preserves volatile state
- Maintains incident log and evidence register
- Communicates containment actions to technical teams

Reporting Analyst / Legal Liaison

- Translates technical findings into executive reports
- Ensures regulatory notification obligations are met
- Coordinates with legal counsel on disclosure/evidence
- Maintains lessons-learned documentation and playbooks

IR Lifecycle - NIST / SANS 6-Phase Model



1 Preparation

- ▶ Build and train the IR team - assign clear roles (IR Lead, Forensic Examiner, Legal, Comms)
- ▶ Develop and rehearse playbooks for common incident types (ransomware, BEC, insider threat)
- ▶ Stage tools: forensic workstations, write blockers, SIEM access, out-of-band comms
- ▶ Establish communication trees and escalation paths before an incident occurs

2 Detection & Analysis

- ▶ Determine incident scope: what systems, data and users are affected?
- ▶ Identify Indicators of Compromise (IOCs): hashes, IPs, domains, registry keys
- ▶ Classify severity and escalate accordingly - declare major incident if warranted
- ▶ Preserve volatile evidence (memory, active connections) before containment

3 Containment

- ▶ Short-term: isolate affected hosts (network quarantine, EDR isolation) to stop spread
- ▶ Long-term: patch exploited vulnerabilities, reset compromised credentials
- ▶ Maintain a forensic copy of affected systems before wiping
- ▶ Coordinate with IT and business to minimise operational disruption

Contd..



4 Eradication

- ▶ Remove malware, backdoors, scheduled tasks, and persistence mechanisms
- ▶ Remediate compromised accounts: disable, reset passwords, revoke tokens
- ▶ Apply missing patches and harden misconfigurations that enabled access
- ▶ Validate eradication - confirm no remnants via EDR and forensic review
- ▶ Re-image or restore from clean backup where full confidence cannot be achieved

5 Recovery

- ▶ Restore systems from verified clean backups or re-imaged builds
- ▶ Reconnect to network in phases - monitor closely for signs of reinfection
- ▶ Re-enable services only after eradication is confirmed
- ▶ Communicate status to stakeholders and affected users clearly
- ▶ Maintain heightened monitoring for 30–90 days post-incident

6 Lessons Learned

- ▶ Conduct post-incident review within 2 weeks while details are fresh
- ▶ Perform root-cause analysis: how did the attacker get in, persist, and move?
- ▶ Identify control gaps and assign owners for remediation actions
- ▶ Update playbooks, detection rules, and runbooks based on findings
- ▶ Report to leadership: what happened, business impact, cost, and improvements

Types of Forensics



System Forensics



Network Forensics



Cloud Forensics



Mobile Forensics



System Forensics Artifacts



File System Artifacts

- File Metadata
- File carving

Operating System Artifacts

- Event logs
- Registry Entries
- System Configuration Files

Application Artifacts

- Browser history
- Email data
- Application Logs

Network Artifacts

- Network traffic logs
- IP addresses & Connections

User Artifacts

- Recent documents
- User profiles
- Shell History

Evidence Chain of Custody

- A documented record of who collected, handled, transferred or analysed every piece of evidence.
- Covers: who received it, when, from where, storage conditions, and every person who accessed it.
- Any break in custody can render evidence inadmissible in court.
- Applies to physical media, disk images, memory dumps, log exports and email archives.
- Must be maintained even for internal investigations - assume legal proceedings may follow.



Evidence Chain of Custody



Required Documentation Fields

- Case ID & evidence item number
- Date, time and location of collection
- Collector name, role and signature
- MD5 / SHA-256 hash verified at collection
- Storage medium type and label
- Transfer log - every handover documented

Forensic Hashing & Write Blockers

- Always hash evidence at collection - MD5 for speed, SHA-256 for legal strength
- Verify hash after imaging and at every transfer to confirm integrity
- Hardware write blockers prevent any modification to original media
- Software write blockers (Arsenal Recon, FTK) acceptable for live triage
- Store hash values in the case management system - not on the evidence itself

Evidence Handling Basics

- Record who received the sample, when, from where and why it is being analyzed.
- Hash original evidence before analysis and keep an untouched copy.
- Use clear labels: case ID, sample ID, analyst, date and environment.
- Separate facts from assumptions in notes; preserve screenshots and tool output.
- Changing file extension.
- Running in a VM only! (Isolated VM, Sandbox environment)

Core Principles

Hash

Integrity

Snapshot

Repeatability

Timeline

Defensible notes



Forensics Data Collection Tools

- Cyber Triage
- Kape
- Velociraptor
- Thor
- GSI
- FTK Imager
- Cellebrite
- X-Ways Forensics
- Loki
- Dumpit
- Magnet Axiom
- Wireshark
- Red Line
- Volatility 3
- Zeek / Suricata
- Autopsy



Artefacts: File System



Artifact	Purpose	Extraction Tool / Path
\$MFT (Master File Table)	Records every file and directory on NTFS - name, size, timestamps (Created, Modified, Accessed, Changed), attributes and data location	FTK Imager or KAPE (\$MFT target); parse with MFTECmd, Autopsy
\$LogFile / \$UsnJrnl:\$J	NTFS journals track file-system changes in sequence - reveals files recently created, renamed, moved or deleted even after deletion	KAPE (UsnJrnl target), MFTECmd, fsutil usn readjournal - path: \ \$Extend \ \$UsnJrnl
Alternate Data Streams (ADS)	Hidden data attached to NTFS files - used by malware to conceal payloads or configuration without altering visible file size	dir /r, Streams.exe (Sysinternals), X-Ways Forensics - Zone.Identifier ADS marks downloaded files
Prefetch Files	Windows pre-loads frequently-run executables - records application name, run count, last 8 run times, and files referenced	C:\Windows\Prefetch*.pf - PECmd (EZ Tools), KAPE, WinPrefetchView; must enable on servers

Artefacts: File System



Artifact	Purpose	Extraction Tool / Path
Amcache.hve	Tracks recently executed programs - records SHA-1 hash, file path, publisher, compile time - survives file deletion	C:\Windows\appcompat\Programs\Amcache.hve - AmcacheParser (EZ Tools), KAPE
Shimcache (AppCompatCache)	Tracks executables that interacted with the Windows Application Compatibility subsystem - execution evidence even without Prefetch	HKLM\SYSTEM\...\Session Manager\AppCompatCache - AppCompatCacheParser
LNK Files (Shortcuts)	Auto-created when a file is opened - records original file path, volume serial, MAC timestamps, target file metadata	...\AppData\Roaming\Microsoft\Windows\Recent\ - LECmd (EZ Tools), KAPE
Jump Lists	Taskbar/Start Menu recently accessed files per application - persists evidence of opened documents even after deletion	...\Recent\AutomaticDestinations\ - JLECmd (EZ Tools)

Artefacts: Windows Registry



Artifact	Purpose	Extraction Tool / Path
SAM Hive - Accounts & Hashes	Local user accounts, password hashes (NTLM), login count, last logon time, account flags (locked/disabled/admin)	C:\Windows\System32\config\SAM (requires SYSTEM key to decrypt) - RegRipper, KAPE
SYSTEM Hive - Hardware & Services	Current control set, mounted devices, installed services and drivers, USB device history (USBSTOR), timezone, computer name	C:\Windows\System32\config\SYSTEM - RegRipper (system plugin), KAPE, Registry Explorer
SOFTWARE Hive - Installed Programs	Installed applications, OS version, registered file associations, auto-start entries (Run/RunOnce), shell extensions	C:\Windows\System32\config\SOFTWARE - RegRipper (software plugin), Registry Explorer

Artefacts: Windows Registry



Artifact	Purpose	Extraction Tool / Path
NTUSER.DAT - User Activity	Per-user hive: recently opened files (MRU), typed URLs, search history, UserAssist (GUI execution), shell bags	C:\Users\%username%\NTUSER.DAT - RegRipper (ntuser), Registry Explorer, ShellBagsExplorer
USRCLASS.DAT - Shell Bags	Records folder access history including network shares and removable media - even if the folder no longer exists	...\AppData\Local\Microsoft\Windows\UsrClass.dat - ShellBagsExplorer
Run / RunOnce Keys (Persistence)	Auto-start locations abused by malware for persistence - executes payload every user login or system boot	HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run / RunOnce - Autoruns, RegRipper
Services Key	All installed Windows services including malicious ones - name, binary path, start type, and account context	HKLM\SYSTEM\CurrentControlSet\Services - sc query, Autoruns, RegRipper (compare to baseline)

Artefacts: Logs & Applications



Artifact	Purpose	Extraction Tool / Path
Windows Event Logs (EVTX)	Security (4624 logon, 4625 fail, 4648 explicit, 4688 process create), System, Application, PowerShell, Sysmon logs	C:\Windows\System32\winevt\Logs\ - KAPE, Chainsaw, EvtxECmd, Hayabusa, Splunk
PowerShell Logging	Module logging, script block logging, and transcripts capture full PowerShell commands - critical for living-off-the-land detection	Script block: Event ID 4104; enable via GPO - parse with Chainsaw
Linux Auth / Syslog	SSH logins, sudo usage, PAM authentication failures, cron jobs, and kernel messages - primary Linux IR source	/var/log/auth.log (Debian) or /var/log/secure (RHEL) - grep, awk, Splunk UF
Bash / Shell History	Records commands typed in terminal sessions - attacker commands, tool downloads, credential use, pivot activity	~/.bash_history, ~/.zsh_history, ~/.python_history - history -a forces flush

Artefacts: Logs & Applications



Artifact	Purpose	Extraction Tool / Path
Browser History & Cache	Visited URLs, search queries, downloaded files, saved credentials, cookies and session tokens - all timestamps preserved	Chrome: %LocalAppData%\Google\Chrome\User Data\Default\ - BrowsingHistoryView, Hindsight, KAPE
Email Artefacts (PST / OST / EML)	Phishing delivery evidence - sent/received messages, attachments, X-Originating-IP headers, meeting invites	Outlook PST: %UserProfile%\Documents\Outlook Files\ - pst-utils, libpff
Application Event Logs	Antivirus detections, backup software logs, database error logs, web server access logs (IIS, Apache, Nginx)	IIS: C:\inetpub\logs\LogFiles\ Apache: /var/log/apache2/access.log - KAPE, Splunk
Installed App Artefacts	MUI Cache (recently run programs), BAM/DAM (background activity), WMI subscriptions (common persistence vector)	BAM: HKLM\SYSTEM\...\Services\bam\State\UserSettings - Get-WMIObject subscription

Artefacts: Network & Memory



Artifact	Purpose	Extraction Tool / Path
PCAP (Full Packet Capture)	Complete network traffic - reconstruct sessions, extract transferred files, identify C2 beacons and exfiltration patterns	Wireshark (filters, stream reassembly, TLS decrypt) - tcpdump, Arkime
NetFlow / IPFIX Records	Source/destination IP, port, protocol, byte count, packet count, duration - no payload but scalable across large networks	Router/firewall exports; Zeek conn.log - ntopng, ElasticFlow, Splunk
DNS Query Logs	Reveals C2 domain lookups, DGA activity, tunnelling, and lateral movement DNS patterns	Zeek dns.log, Sysmon Event ID 22, Windows DNS debug log - Passive DNS: PDNS, Farsight DNSDB
Live Memory (RAM) Acquisition	Running processes, injected code, encryption keys, network connections, user credentials - only while system is live	Magnet RAM Capture, DumpIt, WinPmem - Volatility 3: pslist, netscan, dlllist, malfind

Artefacts: Memory & Mobile



Artifact	Purpose	Extraction Tool / Path
pagefile.sys / hiberfil.sys	Virtual memory swap and hibernation snapshot - may contain process memory, strings, credentials evicted from RAM	C:\pagefile.sys, C:\hiberfil.sys - FTK Imager, hibr2bin + Volatility 3
Recycle Bin (\$Recycle.Bin)	Retains deleted files until emptied - metadata preserved: original path, deletion timestamp, user SID	C:\\$Recycle.Bin\%SID%\ - RBCmd (EZ Tools), KAPE
iOS Backup (Cellebrite / MSAB)	Full device backup: messages, call history, app data, location history, keychain secrets, photos with EXIF	Cellebrite UFED, MSAB XRY, iCloud backup: XRY Cloud
Android (ADB / Cellebrite)	App databases (SQLite), call logs, SMS, WhatsApp/Telegram plaintext DBs, location data, browser history	adb backup -all, Cellebrite UFED Android acquisition - SQLite Browser

Network Forensics



Wireshark

- ▶ Packet-level analysis with display filters (ip.addr, tcp.port, http.request, dns)
- ▶ Follow TCP/UDP stream to reconstruct sessions and extract transferred files
- ▶ TLS decryption with pre-master secret key log file (SSLKEYLOGFILE)
- ▶ Export objects: HTTP files, SMB shares, email attachments from PCAP
- ▶ Statistics > Protocol Hierarchy reveals traffic composition at a glance

Zeek (formerly Bro)

- ▶ Generates structured logs: conn.log, dns.log, http.log, ssl.log, files.log
- ▶ conn.log: every connection - src/dst IP, port, protocol, duration, bytes
- ▶ dns.log: all queries and responses - reveals DGA, tunnelling, C2 lookups
- ▶ http.log: URIs, user-agents, referrers, response codes, transferred bytes
- ▶ Ingest logs directly into SIEM (Splunk, Elastic) for hunt and alerting

Suricata / Snort

- ▶ IDS/IPS with EVE JSON output - alerts, flows, DNS, HTTP, TLS metadata
- ▶ Rule syntax: alert tcp any any -> any 443 (msg:"TLS beacon"; sid:9001;)
- ▶ Emerging Threats and ET Pro rulesets cover known malware C2 patterns
- ▶ Flow logging captures bidirectional traffic stats even without full PCAP
- ▶ Threat hunting: run offline against stored PCAPs with suricata -r file.pcap

Contd..

Arkime (formerly Moloch)

- ▶ Full PCAP indexing at scale - captures and stores gigabytes of traffic for search
- ▶ Web UI: search by IP, port, protocol, user-agent, JA3 TLS fingerprint
- ▶ Session viewer reconstructs raw packet sequences for any conversation
- ▶ API integration with SIEM/SOAR for automated PCAP retrieval on alert
- ▶ Deploy on a TAP or SPAN port; pair with Elasticsearch for index storage

NetFlow / IPFIX / sFlow

- ▶ Flow records capture src/dst IP, port, protocol, bytes, packets, timestamps
- ▶ No payload - scalable to 10Gbps+ where full PCAP is impractical
- ▶ Detect beaconing: regular connections to same IP at fixed intervals
- ▶ Large data transfers: flows with unusually high byte counts = exfil candidate
- ▶ Tools: ntopng, ElastiFlow, nfdump, Splunk Cisco NetFlow TA



Mobile Forensics



Acquisition Types (least → most invasive)

- ▶ Logical: Backup-level data via iTunes/ADB - apps, contacts, messages, media
- ▶ Fastest and least risky - no device modification required
- ▶ Limited: encrypted files, deleted data not recovered
- ▶ Filesystem: Full filesystem image including app containers and temp files
- ▶ Requires device to be unlocked and jailbreak/root
- ▶ Recovers deleted SQLite rows and unallocated app data
- ▶ Physical: Bit-for-bit image of NAND flash - max data recovery
- ▶ May require chip-off, JTAG or EDL mode (advanced/destructive)
- ▶ Recovers encrypted data partitions if key material available
- ▶ Does not require device - needs credentials or legal process
- ▶ May include more data than the device (sync history, old devices)

iOS Forensics

- ▶ Cellebrite UFED: gold standard - physical, logical, filesystem extractions
- ▶ MSAB XRY / Oxygen Forensics: alternative commercial tools with cloud module
- ▶ Key artefacts: KnowledgeC.db (app usage), LocationD (GPS), sms.db, voicemail.amr
- ▶ Keychain: encrypted credential store - decrypted only with physical acquisition
- ▶ Backup encryption: if enabled, password-protect all backup data - attempt crack with Hashcat
- ▶ iFunBox / iMazing: user-friendly logical extraction without jailbreak
- ▶ Unified log (logd): detailed system/app events - parse with 'log' tool or mac_apl

Mobile Forensics



Android Forensics

- ADB (Android Debug Bridge): adb backup -all, adb pull /data (root required)
- Cellebrite UFED / Magnet AXIOM: physical and EDL mode for locked devices
- Key artefacts: mmssms.db (messages), contacts2.db, browser history, call_log.db
- WhatsApp / Telegram: plaintext DBs at /data/data/com.whatsapp/databases/msgstore.db
- Location: com.google.android.gms / fused location, Google Timeline export
- App-specific DBs: SQLite - open with DB Browser for SQLite or sqlitebrowser
- Factory reset forensics: NAND flash carving may recover pre-wipe data fragments

Legal Considerations

- Always document device state: on/off, signal, passcode status
- Place in a Faraday bag immediately to prevent remote wipe
- Image before any analysis begins
- Backup encryption: attempt crack with Hashcat where enabled

Anti-Forensics



Anti-Forensic Technique	Strategy Against It
Disk Wiping	Regular Backups
Log Manipulation / Deletion	Centralized Log Collection
Timestomping	File Metadata Analysis / \$MFT Forensics
Steganography	Steganalysis Tools (StegDetect, binwalk)
Encrypted Containers	Header Carving, Known-Plaintext & Key Recovery

Attack & Incident Analysis - Cyber Kill Chain



1 Recon

Target research, OSINT, scanning for vulnerabilities and identifying employees

2 Weaponise

Attacker packages exploit + payload into a deliverable (email, document, link)

3 Deliver

Payload delivered to the target via chosen vector

4 Exploit

Exploit triggers on victim system - CVE, zero-day, or user action

5 Install

Malware establishes a foothold - persistence mechanisms deployed

6 C2

Malware phones home - attacker gains remote control of the system

7 Objective

Attacker executes their goal – exfiltration, destruction, or ransom

IoCs / IoAs & Their Types



IOC - Indicator of Compromise

They are forensic artifacts from intrusions that are identified on organizational information systems (at the host or network level).

Indicator of Compromise is an unexpected activity that may indicate that a system has been compromised

Example:

IP Address, User, Suspicious Emails, Process IDs.

IOA - Indicator of Attack

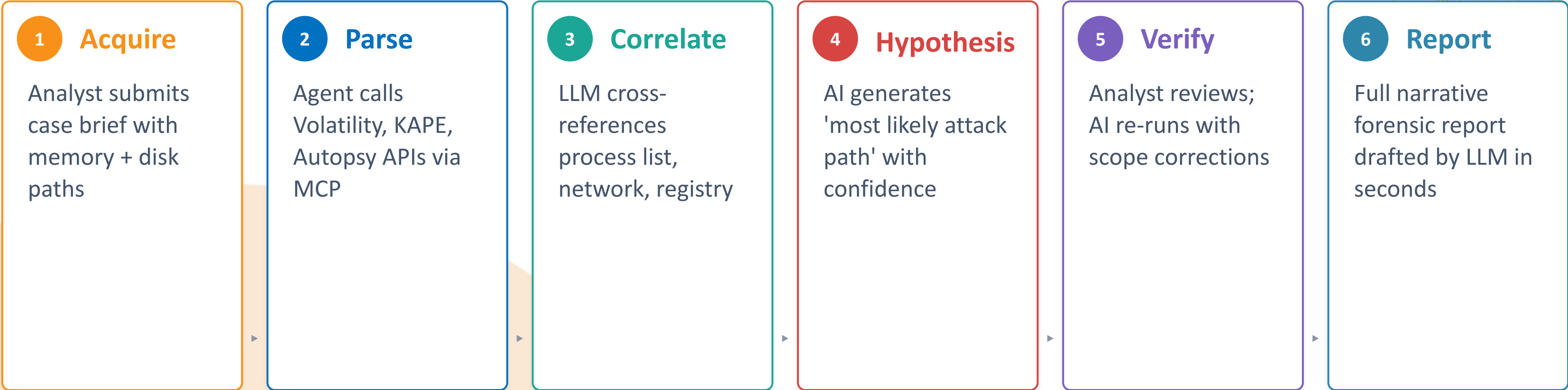
Indicators of Attack (IoAs) are clues and evidence of a data breach. These digital breadcrumbs can reveal just that an attack has occurred.

Indicator of Attack indicates that an attack is in progress.

Example:

Malware signature detection , unexpected file downloads, Abnormal network activity.

AI-Assisted Forensics via MCP



Malware Analysis



Malware Analysis is the process of examining a malicious file, program, or activity to understand:

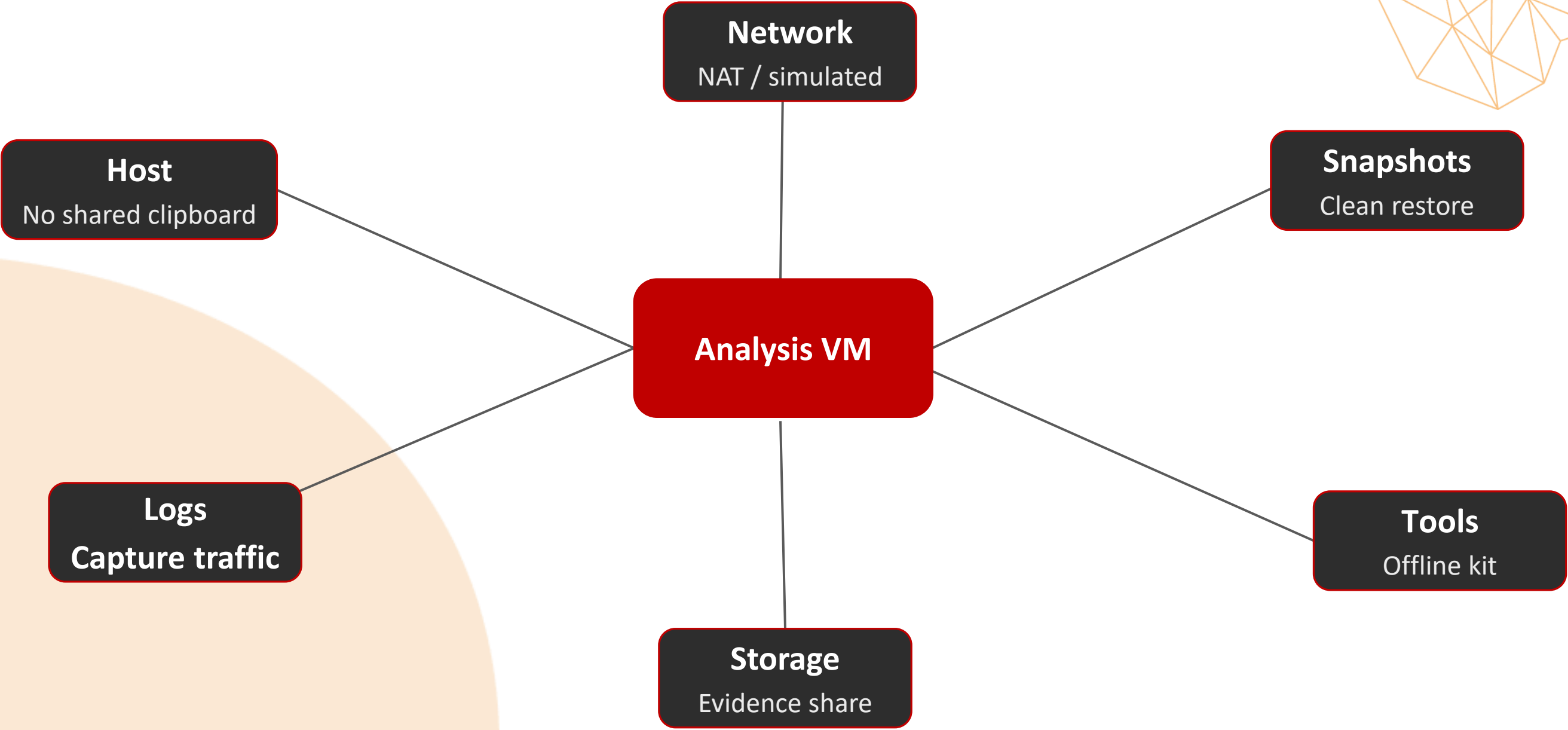
-  What it does
-  How it infects and impacts a system
-  What systems, files, or network resources it interacts with
-  How it maintains persistence or evades detection
-  How defenders can detect, contain, and respond to it

Malware Types



Type	Typical Behavior	Analyst Focus
RAT	Remote control, persistence, command execution	C2, persistence, credentials, lateral movement
Ransomware	Encrypts files and demands payment	Encryption path, kill switch, impacted shares
Wiper	Destroys data or boot records	Destructive logic, trigger conditions, recovery impact
Spyware	Captures keystrokes, files, audio/screens	Exfiltration, collection scope, targeted users

Safe Analysis Environment



Static Analysis Workflow



1 Identify

- Determine file type
- Check file size
- Note filename & extension
- Look for suspicious characteristics

2 Hash

- Determine file type
- Check file size
- Note filename & extension
- Look for suspicious characteristics

3 Strings

- Extract readable strings
- Look for URLs & IPs
- Identify file paths & commands
- Spot suspicious keywords

4 PE Review

- Examine imports & exports
- Review PE sections
- Check compilation details
- Identify packing or obfuscation

5 Decide

- Assess indicators of compromise
- Determine malware likelihood
- Decide whether to detonate
- Escalate for deeper analysis

Hashing, Reputation & Strings

- Hashes provide unique fingerprints for searching, sharing and de-duplication.
- Strings can reveal domains, IPs, registry keys, paths, mutexes and command usage.
- Reputation checks are useful, but avoid uploading sensitive government samples publicly.
- Look for packed/encrypted samples when strings are sparse or section entropy is high.

SHA256

Primary sample ID

Strings

Clues, not proof

Reputation

Use policy first



PE Studio & PE Header Inspection

- Review compile timestamp, imports, exports, resources, sections and signatures.
- Suspicious imports can suggest networking, process injection, persistence or crypto behavior.
- Check section names, sizes and entropy for packing or abnormal layout.
- Document observations as leads; confirm behavior dynamically where safe.

Headers

Architecture + timestamp

Imports

API intent clues

Sections

Packing indicators

Resources

Icons / config



Reverse Engineering - Workflow



1 Identify

File type, arch,
packer - file,
ExifTool,
Detect-It-Easy

2 Strings

Extract URLs,
IPs, keys,
mutexes -
strings, FLOSS,
Mandiant

3 Imports

API calls reveal
capability -
PEview, PE
Studio, CFF
Explorer

4 Disasm

Static
disassembly -
Ghidra, IDA Pro,
Radare2/Cutter

5 Debug

Dynamic step-
through -
x64dbg,
OllyDbg, GDB
(Linux)

6 Document

IOCs, MITRE
ATT&CK TTPs,
YARA rule,
analyst report

Reverse Engineering



Ghidra (NSA / Free)

- ▶ Full decompiler - produces readable C pseudocode from x86/ARM/MIPS binaries
- ▶ Scripting: Python (PyGhidra) and Java for automated analysis and IOC extraction
- ▶ GhidraMCP: AI agent calls Ghidra API - auto-renames functions, maps data flows
- ▶ CodeBrowser: cross-reference functions, follow call graphs, annotate behaviour
- ▶ Share project databases with team - collaborative reverse engineering

IDA Pro (Industry Standard)

- ▶ World's most powerful interactive disassembler - x86, x64, ARM, MIPS, PPC
- ▶ IDA Python scripting: automate repetitive analysis, bulk rename, decrypt strings
- ▶ Lumina server: function matching against a cloud database of known signatures
- ▶ Hex-Rays decompiler (paid addon): C pseudocode from compiled binaries
- ▶ BinaryAI plugin: AI-assisted function identification and similarity matching

Contd..

Obfuscation & Deobfuscation

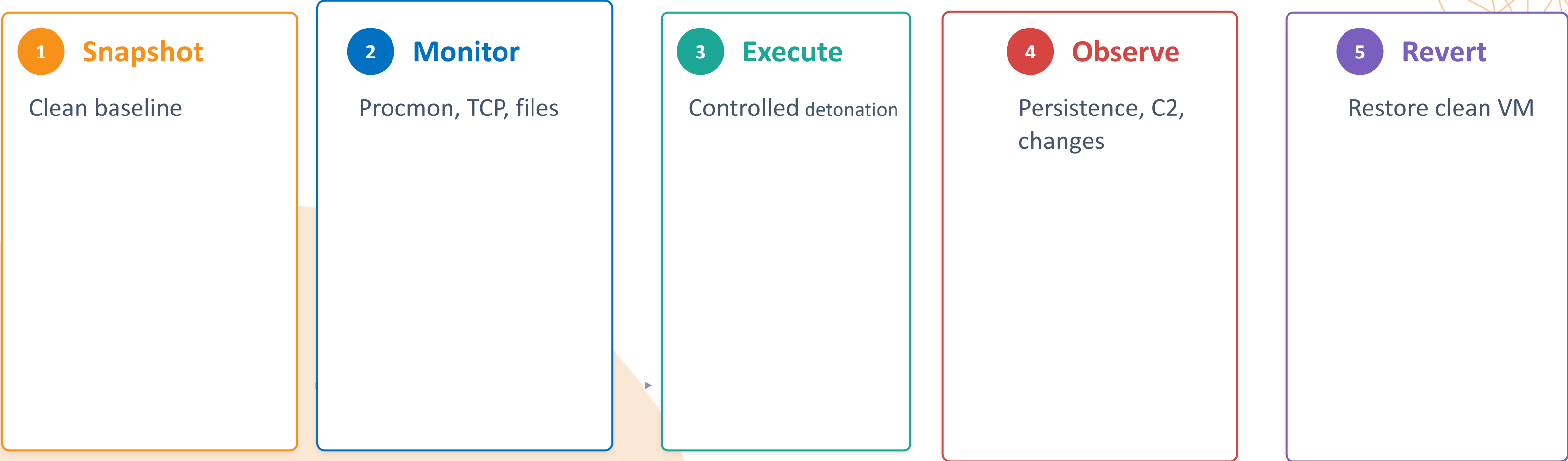
- ▶ String encryption: XOR loop decryption - identify key, write YARA or IDAPython
- ▶ Packing: UPX (upx -d), custom packers - find OEP, dump, rebuild imports
- ▶ Control flow flattening: use Hex-Rays + D-810 plugin or Ghidra scripts
- ▶ FLOSS (FireEye): automatically extracts obfuscated strings from binaries

x64dbg / OllyDbg / GDB

- ▶ x64dbg: Windows dynamic debugger - breakpoints, memory inspection, anti-debug bypass
- ▶ OllyDbg: legacy 32-bit debugger still used for older malware families
- ▶ GDB + PEDA/pwndbg: Linux binary debugging with enhanced display and scripting
- ▶ ScyllaHide plugin: bypass common anti-debugging and VM detection checks



Dynamic Analysis Workflow



Indicators & Analyst Reporting

- Extract file hashes, filenames, registry keys, mutexes, persistence paths and domains/IPs.
- Classify IOCs by confidence: observed, derived or suspected.
- Map behaviors to tactic stages: execution, persistence, defense evasion, C2, exfiltration.
- Report what happened, affected systems, business risk and containment recommendations.

Observed	Seen in analysis
Derived	From config/logic
Suspected	Needs validation
Actionable	Can be blocked/searched



AI Assisted Malware Analysis



VirusTotal Code Insight

- Gemini-powered: explains suspicious scripts and code
- Identifies likely malware behaviour
- Highlights credential theft, persistence or network activity

ANY.RUN AI

- Detonates samples in an interactive sandbox
- Summarizes execution behaviour
- Highlights suspicious processes, files, registry changes and network traffic

GhidraMCP

- Connects AI agents to Ghidra
- Automated decompilation review and function analysis
- Behaviour detection, renaming and IOC extraction

AI-Based IOC Extraction

- Analyzes strings, imports, sandbox logs and network captures
- Identifies domains, IPs, mutexes, registry keys and persistence paths

AI-Generated Detection Rules

- Converts observed malware behaviour into draft rules
- YARA, Sigma, Suricata or EDR hunting rules
- For analyst validation before deployment

AI vs. Traditional Security Tools



Feature	Traditional Tools	AI-Powered Tools
Detection Method	Signature / rules-based	Behavioural & anomaly-based
New Threats	Misses' unknown variants	Detects novel patterns
Alert Volume	High false positives	Prioritised, contextualised
Response Speed	Manual triage (hours–days)	Automated triage (seconds)
Analyst Effort	High - repetitive tasks	Reduced - focus on decisions
Adaptability	Static until manually updated	Learns continuously
Explainability	Rule is visible	Varies (black-box risk)

AI Across the IR Lifecycle



Preparation

Threat intel enrichment; playbook generation; attack simulation (red-team AI)

Detection & Analysis

SIEM anomaly detection; auto-triage of alerts; LLM-generated alert summaries

Containment

Automated host isolation; dynamic firewall rule push; similar-incident lookup

Eradication

Malware family identification; persistence path mapping; AI-suggested remediation

Recovery

Service health monitoring; re-infection pattern watch; recovery checklist generation

Lessons Learned

Root-cause narrative drafting; gap-to-control mapping; automatic playbook updates

AI Across the IR Lifecycle



Alert Triage Automation

SOAR + LLM reads a raw alert, queries threat intel, scores severity, and generates a one-paragraph analyst brief - in under 10 seconds.

Copilot for Security (MS)

Natural language interface to Sentinel: ask 'what happened on host X in the last 24h?' and get a structured incident summary with KQL queries.

AI-Assisted RCA

After containment, an LLM correlates timeline events, maps TTPs to MITRE ATT&CK, and drafts the lessons-learned section of the report.

AI-Powered SIEM & Alert Triage



1 Ingest

All logs, events, and alerts arrive in the SIEM

2 Score

ML model ranks each alert by risk (0–100)

3 Group

Related alerts clustered into one incident

4 Enrich

LLM adds context: who, what, when, why

5 Action

Analyst sees prioritised queue + AI brief

AI-Powered SIEM



Behavioural Baselines

- UEBA profiles normal user activity
- Deviations flagged automatically
- Works even for zero-day threats

Automated Enrichment

- VirusTotal / MISP API lookups
- Geo-IP, WHOIS, ASN context
- Historical match from threat intel feeds

LLM Alert Summary

- Plain-English 'what happened' narrative
- Recommended next investigation steps
- Mapped to MITRE ATT&CK technique

AI Risks, Limitations & Responsible Use



Hallucination

- LLMs confidently state wrong facts.
- Always verify AI-generated IOCs, paths, and hashes against raw evidence.

Adversarial Evasion

- Attackers craft inputs to fool ML models.
- AI detectors can be bypassed with subtle obfuscation.

Data Privacy

- Submitting samples to public AI APIs leaks sensitive data.
- Use air-gapped or on-premise AI for classified investigations.

Black-Box Bias

- ML models trained on old data miss emerging threats.
- Regularly retrain and red-team your AI systems.

Over-Reliance

- AI triage misses 5–15% of real threats (false negatives).
- Maintain human review; AI is a filter, not a wall.

Legal / Chain of Custody

- AI-generated conclusions may not be court-admissible.
- Document every AI decision step; analyst must attest findings.

Responsible AI Use in DFIR - Principles

- Human-in-the-loop: AI recommends, analyst decides.
- Validate: cross-check AI output against raw artefacts before acting.
- Log AI decisions: treat AI calls as part of the audit trail.
- Use private / on-prem AI for sensitive cases - never upload live malware or PII to public APIs.





Thank You!

